Information Security Policy

Acme Cloud Services KSA — Document ACS-POL-001, version 4.2, approved January 2026.

Synthetic demo document. Acme Cloud Services KSA is a fictional company and the controls, certificates and figures below are invented for testing.

1. Scope and governance

Acme Cloud Services KSA operates a certified Information Security Management System (ISMS) covering all production platforms, corporate IT, and the personnel who operate them. The ISMS is owned by the Chief Information Security Officer, who reports to the Board Risk Committee quarterly. The Information Security Steering Committee meets monthly and is the approval authority for policy exceptions.

Every employee and contractor completes mandatory security awareness training on joining and annually thereafter. Quarterly simulated phishing campaigns are run against all staff; the measured click rate for 2025 was 3.2 percent, against an internal target of below 5 percent.

2. Certifications and independent assurance

Acme Cloud Services KSA holds ISO/IEC 27001:2022 certification, certificate ACS-27001-2024, issued by the Gulf Certification Bureau and valid from March 2025 to March 2028. The scope covers cloud hosting, managed platform services and supporting corporate functions.

- ISO/IEC 27017:2015 (cloud-specific controls) — certified June 2025.
- ISO/IEC 27018:2019 (protection of PII in public cloud) — certified June 2025.
- SOC 2 Type II — audited annually by Northgate Assurance LLP; the most recent report covers 1 November 2024 to 31 October 2025 and was issued with no exceptions.
- PCI DSS v4.0 — Acme completes an annual SAQ D as a service provider. Acme is not a fully certified Level 1 service provider and does not store primary account numbers.
- NCA Essential Cybersecurity Controls (ECC-1:2018) — self-assessed at 92 percent compliance in the Q4 2025 cycle, with the remaining items tracked to closure by Q3 2026.
- NCA Cloud Cybersecurity Controls (CCC-1:2020) — assessed as compliant in the Cloud Service Provider tier in September 2025.

Certificates and the SOC 2 report are available to customers under NDA through the Acme Trust Portal. Acme does not hold FedRAMP authorisation and has no plans to pursue it, as it serves no United States federal customers.

3. Cryptography

All customer data is encrypted at rest using AES-256-GCM. Encryption is applied at the storage volume and object layers, and separately at the database layer for fields classified as Confidential or Restricted. Data in transit is protected with TLS 1.3; TLS 1.2 is the minimum accepted version and is permitted only for named legacy integrations under a documented exception that expires in December 2026. SSL v3, TLS 1.0 and TLS 1.1 are disabled.

Key management uses envelope encryption. Data encryption keys are wrapped by customer master keys held in AWS Key Management Service backed by hardware security modules validated to FIPS 140-2 Level 3. Master keys are rotated annually and on any suspected compromise. Customers on the Enterprise tier may supply their own keys (BYOK). No Acme employee can export key material in plaintext; key administration requires two-person authorisation.

Acme's cryptographic standard is reviewed annually against NCA and NIST guidance. The current approved algorithm set is AES-256, RSA-3072, ECDSA P-256 and SHA-256 or stronger.

4. Logging and monitoring

A 24/7 Security Operations Centre monitors the estate. Security events from infrastructure, applications, identity providers and network devices are forwarded to a central SIEM. Logs are retained for 36 months in total: 12 months in hot storage available for immediate query and a further 24 months in immutable cold storage. Log integrity is protected by write-once object locking, and administrator access to the logging platform is itself logged and reviewed.

Mean time to detect for 2025 averaged 12 minutes, and mean time to respond for critical incidents averaged 3.5 hours.

5. Vulnerability and patch management

Infrastructure and container images are scanned continuously; application code is scanned on every merge with static analysis and software composition analysis. Findings are remediated against the following service levels, measured from the time of validation.

Severity	Remediation SLA	2025 attainment
Critical (CVSS 9.0-10.0)	7 calendar days	99.1%
High (CVSS 7.0-8.9)	30 calendar days	97.4%
Medium (CVSS 4.0-6.9)	90 calendar days	95.0%
Low (CVSS 0.1-3.9)	180 calendar days	93.8%

Critical operating system patches are deployed to production within 14 days of vendor release, or within 72 hours where a vulnerability is being actively exploited in the wild.

An independent external penetration test of the production platform is commissioned annually from Cipherpoint Security; the most recent test concluded in October 2025 and all high findings were closed within 30 days. Internal penetration testing is performed quarterly. Acme also operates a private bug bounty programme. Physical penetration testing of the data centres is not performed by Acme, as the facilities are operated by the hosting provider.

6. Personnel and physical security

All employees undergo identity verification and criminal background screening before their start date, and sign a confidentiality agreement covering the duration of employment and five years thereafter. Staff with production access are re-screened every three years.

Production workloads run in Riyadh with disaster recovery in Jeddah. Both facilities are Tier III, operated under ISO 27001 and SOC 2 certified physical security programmes, with biometric access control, 24/7 guarding and 90-day CCTV retention. Acme personnel do not have unescorted physical access to customer hardware.